

Lab 3.1 — OPA Policy Engine: Autorización ABAC para Agentes

Qué es este lab

Prueba si la autorización de un agente depende de un enforcement point real -un Policy Decision Point externo que puede decir que no- o solo de que el LLM "se porte bien". Es la contraparte agéntica del patrón de Broken Access Control / Excessive Agency: cada tool del agente consulta a OPA (Open Policy Agent) con una política Rego ABAC antes de ejecutar la acción, no después.

Las piezas que corren

- **OPA (Open Policy Agent):** servidor de políticas standalone, corriendo en un contenedor Docker, expuesto en `localhost:8181`. Evalúa la política Rego `agent_authz` y responde `allow / deny / decision` vía API REST.
- **Política Rego (`agent_authz`):** default-deny, con reglas ABAC por `spiffe_id`, bloqueo incondicional de `DELETE` en rutas `/production/*` (con precedencia explícita vía la regla combinada `decision := allow AND NOT deny` -en Rego, `deny` no sobrescribe `allow` automáticamente, hay que combinarlas a mano), y una regla de horario laboral para el rol `report-writer`.
- **`check_opa()`:** helper de enforcement que se llama de forma inline desde cada tool, antes de ejecutar la acción real. Si OPA deniega, la tool corta ahí y nunca llega a "hacer" nada.
- **`financial_analyzer_opa`:** el agente, modelo `qwen3.5:9b` local vía Ollama. Tools: `get_sales_data` (lectura, casi siempre permitida) y `delete_sales_data` (borrado, casi siempre denegada por política).

El flujo

1. Se levanta OPA vía Docker y se carga la política Rego.
2. El agente recibe un pedido en lenguaje natural.
3. El LLM decide qué tool invocar.
4. La tool, antes de hacer cualquier otra cosa, consulta a OPA con `check_opa()` -arma el `input` (subject/resource/action) y pide la decisión.
5. Si OPA deniega, la acción nunca se ejecuta, sin importar qué haya decidido el LLM.
6. Se puede modificar la política en runtime (recargarla en OPA) y verificar que el comportamiento cambia sin tocar ni redeployar el agente.

Por qué importa la verificación

El enforcement point es OPA, no el LLM -por eso la evidencia de efecto no es "el agente dijo que no" sino que la tool nunca completa su lógica: se imprime la decisión real (`allow` / `deny`) en cada consulta, y el print de ejecución de la tool solo aparece si la lógica real llegó a correr. Si solo se mirara la respuesta en texto del agente, un LLM podría fabricar una respuesta de "denegado" sin haber consultado a OPA en absoluto -el print de la decisión real es lo que confirma que la política se evaluó de verdad.

Resultado esperado

Con la política original cargada: `get_sales_data` responde con datos reales; `delete_sales_data` es bloqueada por OPA y la tool devuelve un resultado estructurado de denegación, no una excepción sin manejar. Tras cargar en runtime una política modificada que agrega una regla `allow` explícita para DELETE en producción, la misma tool que antes fallaba ahora se ejecuta -sin haber tocado una línea del agente. Una política de límite de trading (\$10.000) permite órdenes de \$5.000 y deniega órdenes de \$15.000.